
Form 5 of 8: Legal and Contracts

Who fills this in: counsel, or whoever signs customer contracts. **Time:** about 10 minutes. **"I do not know" is a real answer.**

Company: _____ Your name: _____ Date: _____

Why legal is in a security review: the obligation that bites first is almost never a regulation. It is a clause in a customer contract nobody has read since signing.

1. Do any signed customer contracts contain security requirements?

☐ Yes ☐ No ☐ Not sure Which customers: _____

2. Can we read those clauses?

☐ Yes ☐ With approval ☐ No

3. Do any contracts require a certification (SOC 2, ISO 27001) by a date?

4. Do any require you to notify a customer of a breach? Within how many hours?

☐ Yes, within _____ hours ☐ No ☐ Not sure

5. Do any give a customer the right to audit you?

☐ Yes ☐ No ☐ Not sure

6. Which of these apply to your business?

☐ GDPR / UK GDPR ☐ US state privacy laws ☐ HIPAA ☐ PCI DSS ☐ CMMC / DFARS ☐ FERPA ☐ Sector specific:
_____ ☐ None formally

7. Do you have Data Processing Agreements with vendors who hold personal data?

☐ Yes, all ☐ Some ☐ No ☐ Not sure

8. Has a customer, regulator, or insurer ever asked you a security question you could not answer?

9. Who signs vendor contracts? Is there a review before signing?

Signer: _____ Review: ☐ Yes ☐ Sometimes ☐ No

10. Do you have a records retention policy? Is it followed?

☐ Written and followed ☐ Written, not followed ☐ None

11. Any current or recent litigation, dispute, or legal hold involving data?

12. Who would you call first if you had a data breach?

Internal: _____ Outside counsel: _____ ☐ Nobody identified

Anything in a contract that worries you and has not been dealt with?
